6 CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat **10:15**. Safran'ın servis/telemetri hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. Ana kontrolcü konfigürasyonu değişmiş olabilir; **hız limiti ve koltuk/ölü adam parametreleri henüz doğrulanmadı.** Makine sahada çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?
   Ararım: bakım/OT sorumlusu, BT/siber güvenlik (olay yöneticisi), üretici servis/ürün güvenliği ekibi, emniyet sorumlusu. **İlk 3 eylem:** (1) Makineyi **kontrollü şekilde güvenli duruma alıp** «hizmet dışı» etiketlerim (emniyet önce). (2) Servis hesabını ve telemetri bağlantısını **izole ederim** (hesap kapat, bağlantı kes). (3) **Kanıtı korurum:** saat, ekran görüntüsü, ne görüldü tutanağı; **reset/güç kesme/yeniden yazma yok**.

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?
   Emniyet doğrulama: safety parametreleri (hız limiti, koltuk zaman aşımı) referans/altın yedekle karşılaştırılır; acil stop, koltuk/ölü adam, park freni fonksiyon testi; doğrulanana dek makine kullanılmaz. **Kanıt:** telemetri ve ana kontrolcü logları, konfig imajı (öncesi/sonrası, hash), oturum ve ağ geçidi kayıtları — salt okunur kopya. **Hesap:** ilgili servis hesabı kapatılır, parola/anahtarlar yenilenir, paylaşılan hesaplar taranır.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?
   Olayın tespit zamanı ve ilk değerlendirme; **etkilenen ürün/model ve firmware sürümü**; aktif sömürü şüphesi var mı; kötü niyetli eylem şüphesi; şu ana kadar alınan önlemler; iletişim sorumlusu. Bildirim yükümlülüğünün kime ait olduğu (üretici/işletici) ve alıcı kurum hukuk/uyum ekibiyle teyit edilir.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?
   Kök neden: nasıl girildi (paylaşılan/zayıf hesap, sürekli açık uzak erişim). **Etki:** hangi parametreler değişti, safety etkilendi mi, kaç makine/filo. **Önlem:** hesap kapatma, MFA/VPN/jump server, yama. **Roller:** olay yöneticisi (koordinasyon), OT/bakım (makine ve konfig doğrulama), BT/siber (log analizi, erişim), ürün güvenliği (CRA bildirimi), hukuk/uyum, müşteri iletişimi.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?
   Telemetri/uzak erişim ve oturum kayıtları, ana kontrolcü olay logları, konfigürasyon yedekleri (önce/sonra + hash), ağ geçidi/güvenlik duvarı logları, zaman damgaları, vardiya tutanağı, alınan aksiyonlar, kök neden analizi, düzeltici önlemler, yama ve sürüm kayıtları, **delil zinciri** (kim, ne zaman, neye erişti).

En sık hata: «Resetleyip devam edelim» — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

Cevaplar tipik bir binilebilir scrubber mimarisi varsayımıyla hazırlanmıştır; makinenin gerçek verileriyle doğrulayın.